

TP Guidé – Chapitre 2

Cartographie des menaces et première analyse de risques d'un environnement data fourni

Ce TP est un TP guidé : chaque étape est accompagnée d'indications visuelles et de questions de compréhension. Il s'appuie sur la cartographie des actifs réalisée au chapitre 1 et enrichit le dossier technique Sécurité 1.

Objectifs

À l'issue de ce TP, vous serez en mesure de :

- Identifier les menaces internes et externes pesant sur l'environnement fourni
- Distinguer menace, vulnérabilité, incident et risque sur des cas concrets
- Analyser les impacts potentiels sur les données et les services
- Formaliser une première analyse de risques priorisée

Contexte / scénario

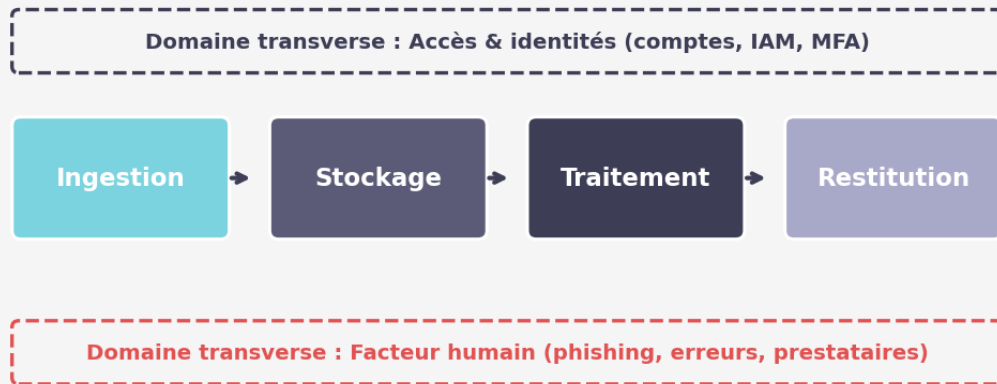
DataCorp Analytics exploite une chaîne de traitement de données comprenant ingestion, stockage, traitement et restitution vers ses clients.

Un audit préliminaire a révélé plusieurs faiblesses potentielles au niveau des accès, du stockage cloud et des flux inter-services.

Votre mission consiste à cartographier les menaces, qualifier les vulnérabilités associées, et produire une analyse de risques exploitable, en continuité avec la cartographie des actifs du chapitre 1.

 **Indication visuelle — Étape 1 : vue d'ensemble de la chaîne de valeur étudiée**

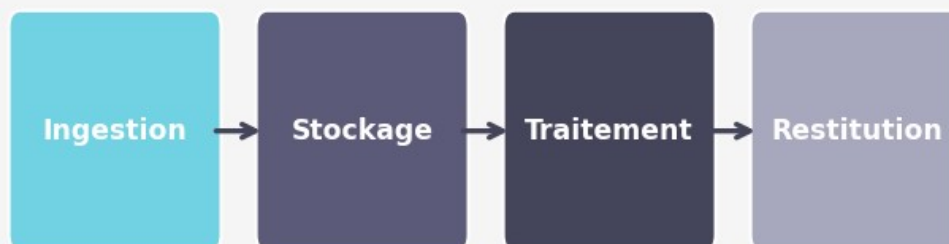
Vue d'ensemble de la chaîne de valeur étudiée



Domaine "Flux" = échanges inter-services entre les 4 étapes ci-dessus (API internes, files, jobs planifiés)

Indication visuelle — Étape 2 : chaîne de valeur data étudiée

Chaîne de valeur data étudiée



Ressources requises

- Schéma de la chaîne de valeur DataCorp Analytics
- Extrait de configuration du stockage cloud
- Journal simplifié des accès récents
- Registre de cartographie des actifs produit au chapitre 1

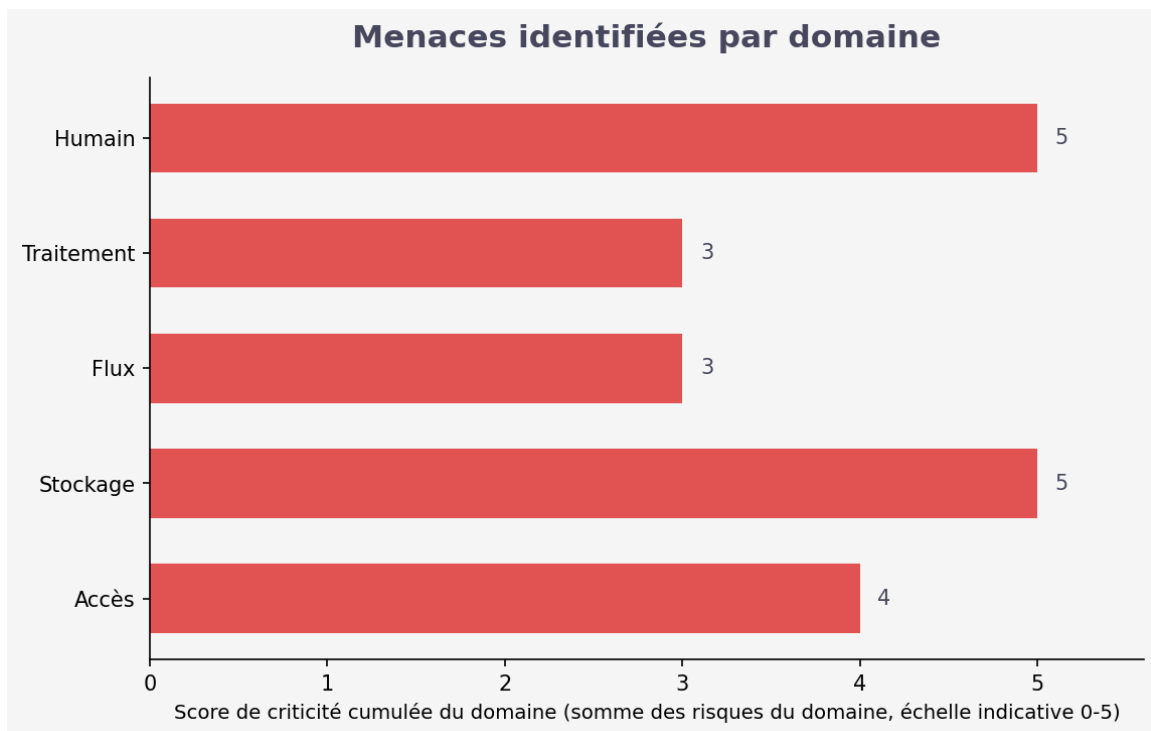
Instructions

Partie a : Cartographie des menaces

1. Parcourez le schéma de la chaîne de valeur DataCorp Analytics fourni.
2. Recensez les menaces internes et externes par domaine (accès, stockage, flux, traitement, humain).

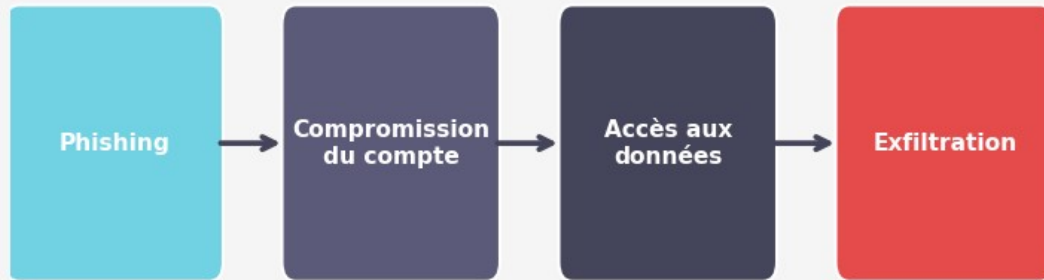
Note : « Accès » et « Humain » sont des domaines transverses — ils traversent les quatre étapes de la chaîne data plutôt que d'en constituer une étape à part (cf. étape 1). « Flux » désigne les échanges entre les étapes.

Indication visuelle — Étape 3 : menaces identifiées par domaine



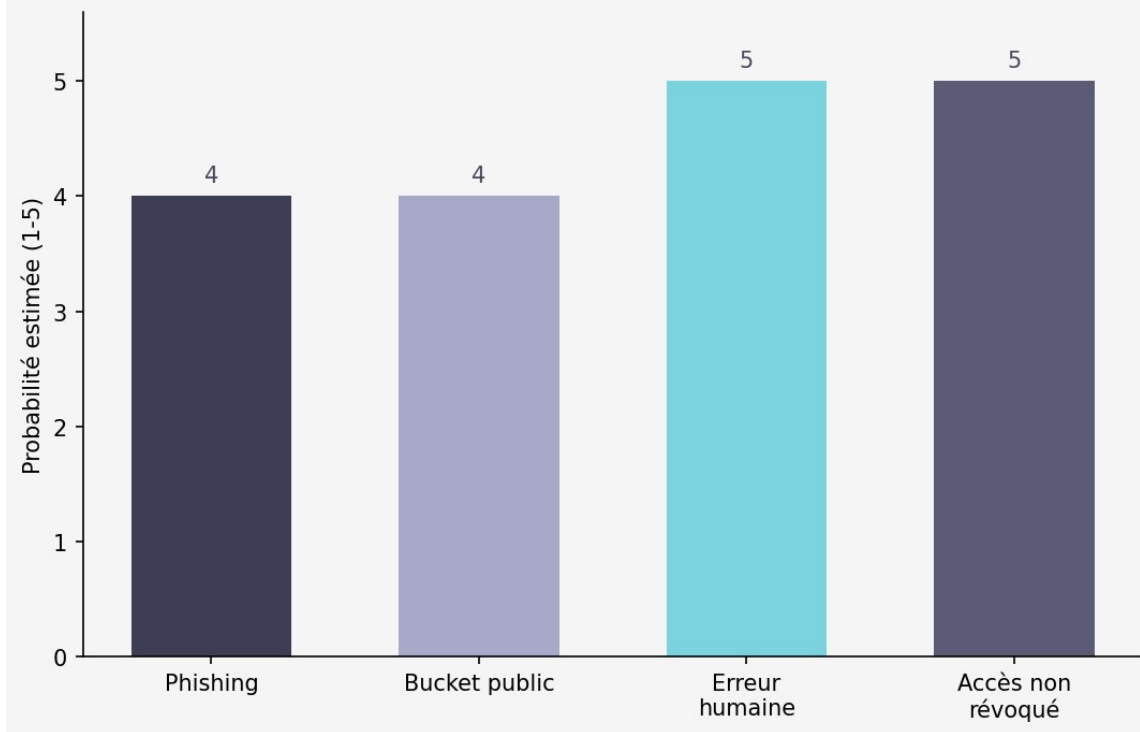
Indication visuelle — Étape 4 : scénario d'incident étudié

Scénario d'incident étudié



Indication visuelle — Étape 5 : probabilité estimée par menace

Probabilité estimée par menace



Questions

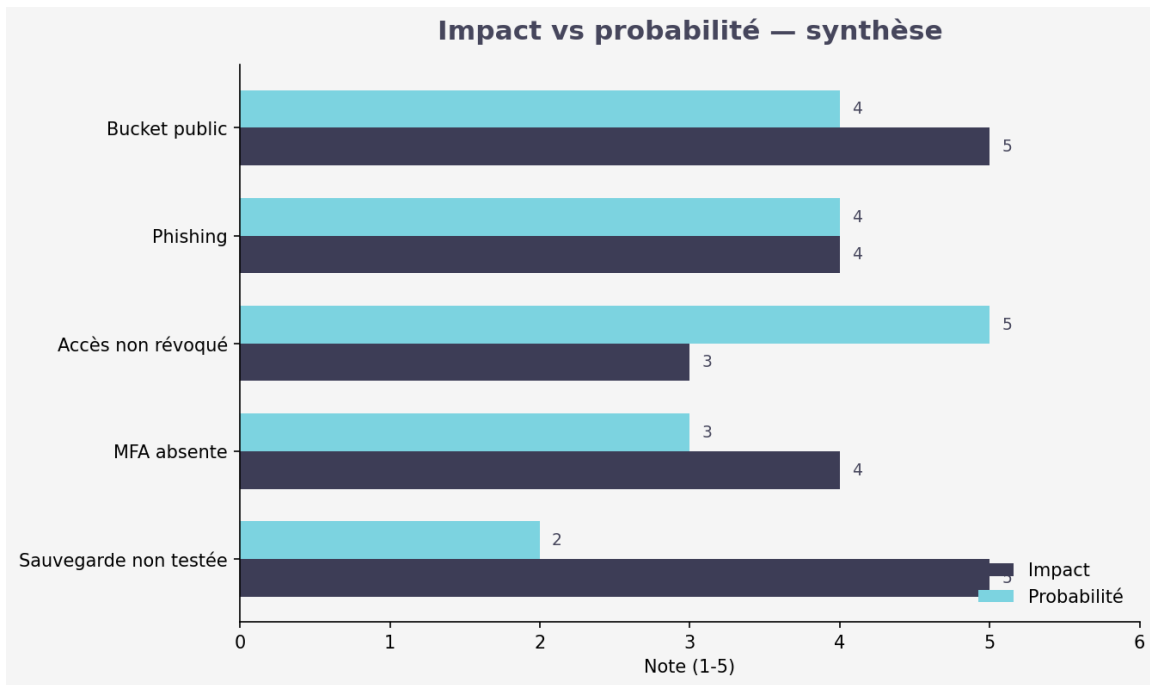
- Combien de menaces distinctes avez-vous recensées, et dans quels domaines ?
- Une menace vous semble-t-elle absente de la description initiale ? Laquelle, et pourquoi ?

Partie b : Estimation impact et probabilité

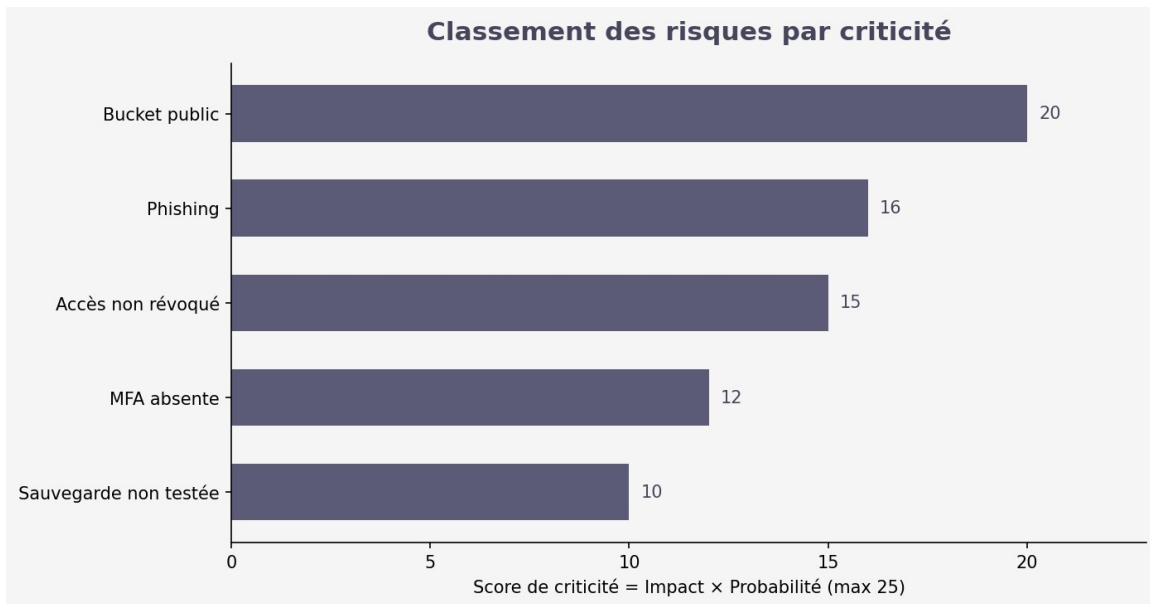
- Estimez la probabilité de chaque menace identifiée à partir des éléments fournis.
- Produisez une synthèse croisée impact/probabilité pour les risques principaux.

Note : le score de criticité utilisé aux étapes 6 et 7 se calcule ainsi : Criticité = Impact × Probabilité (chacun noté de 1 à 5, score max 25). Deux risques supplémentaires apparaissent à partir de l'étape 6 (MFA absente, Sauvegarde non testée) : ils ne figuraient pas dans la liste initiale des menaces (étape 5) car ils proviennent du croisement avec les points d'attention déjà relevés dans le registre de cartographie des actifs du chapitre 1 (A-01 et I-06) — c'est un enrichissement volontaire de l'analyse, pas un oubli.

Indication visuelle — Étape 6 : impact vs probabilité — synthèse



Indication visuelle — Étape 7 : classement des risques par criticité



Questions

7. Quel risque obtient le score de criticité (impact × probabilité, étape 6) le plus élevé ? Justifiez à partir de ses valeurs individuelles d'impact et de probabilité.
8. Un risque vous semble-t-il sous-estimé dans l'audit préliminaire fourni ? Lequel ?

Partie c : Priorisation des risques

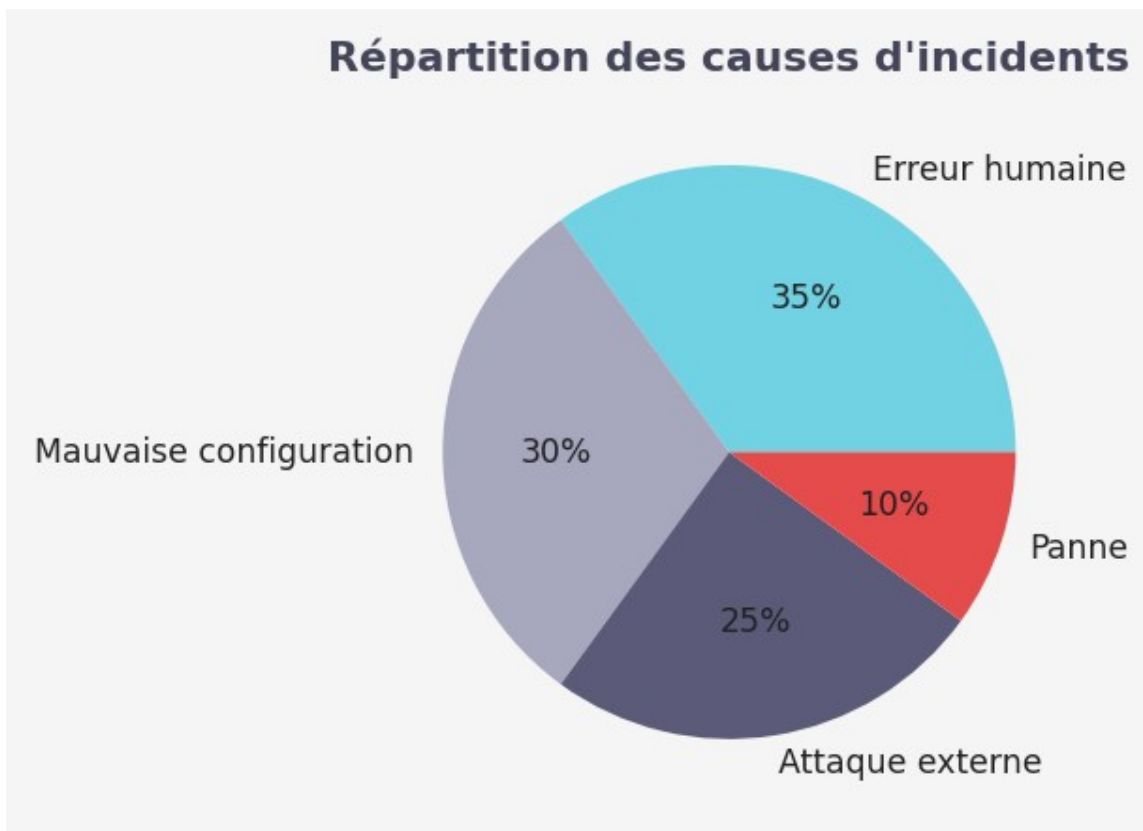
9. Classez les risques identifiés par ordre de criticité.
10. Cartographiez les liens entre menaces et vulnérabilités techniques ou organisationnelles.

Indication visuelle — Étape 8 : cartographie menace/vulnérabilité

Cartographie menace/vulnérabilité (par risque)			
Risque	Technique	Organis.	Cause principale
Bucket public	✓	✓	policy S3 trop permissive + absence de revue de policy
Phishing	✓	✓	pas de filtrage anti-phishing + MFA absent en aval
MFA absente	✓	✓	MFA non configuré + non imposé par la politique IAM
Accès non révoqué	—	✓	processus d'offboarding non suivi (aucune faille technique)
Sauvegarde non testée	—	✓	absence de procédure de test de restauration

Lecture : un risque coché sur les deux colonnes relève à la fois d'une vulnérabilité technique et organisationnelle (cf. question 12).

 Indication visuelle — Étape 9 : répartition des causes d'incidents



Questions

11. Quels sont les trois risques les plus critiques selon votre classement ? Pourquoi ?
12. Un même risque relève-t-il à la fois d'une vulnérabilité technique et organisationnelle ?

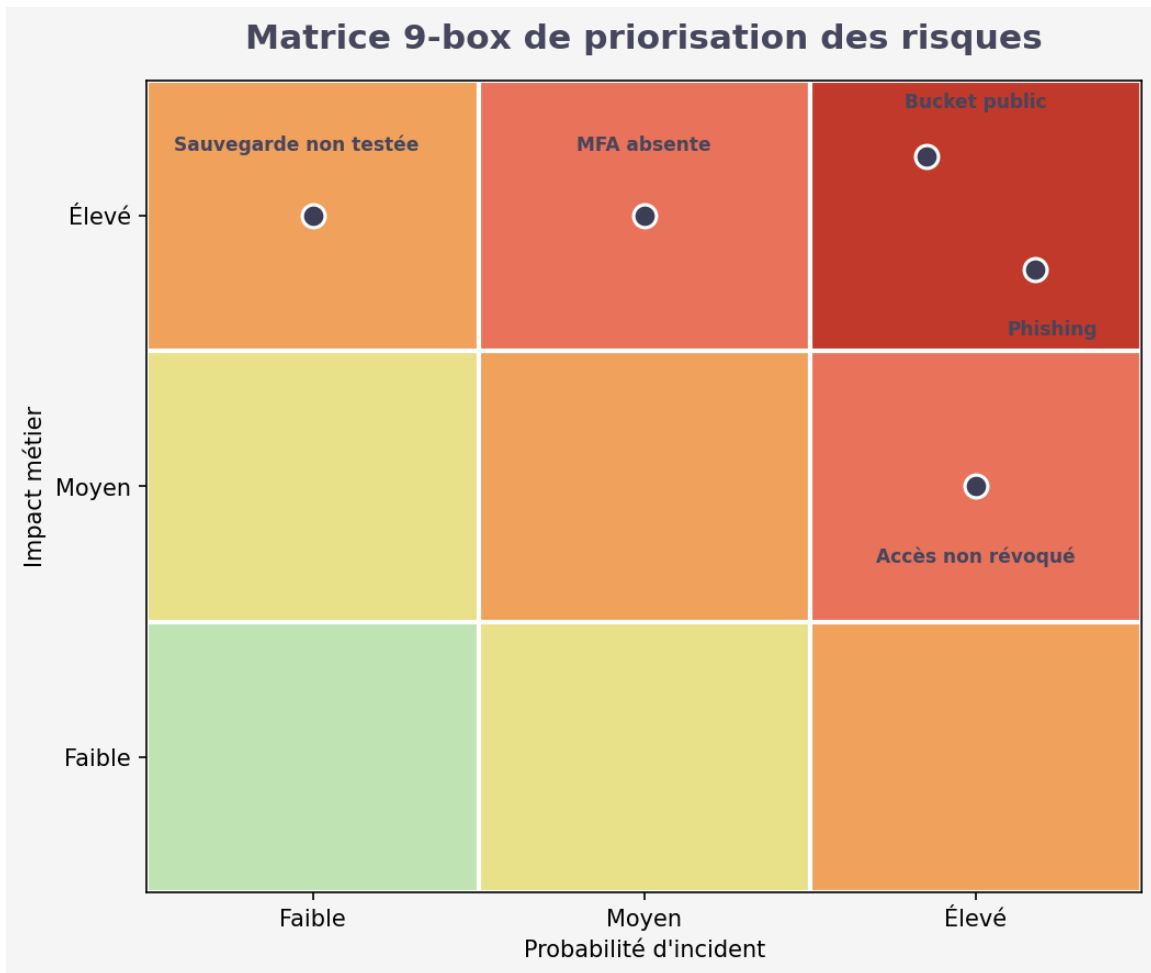
Partie d : Plan de traitement

13. Positionnez les risques recensés sur une matrice 9-box (probabilité × impact).

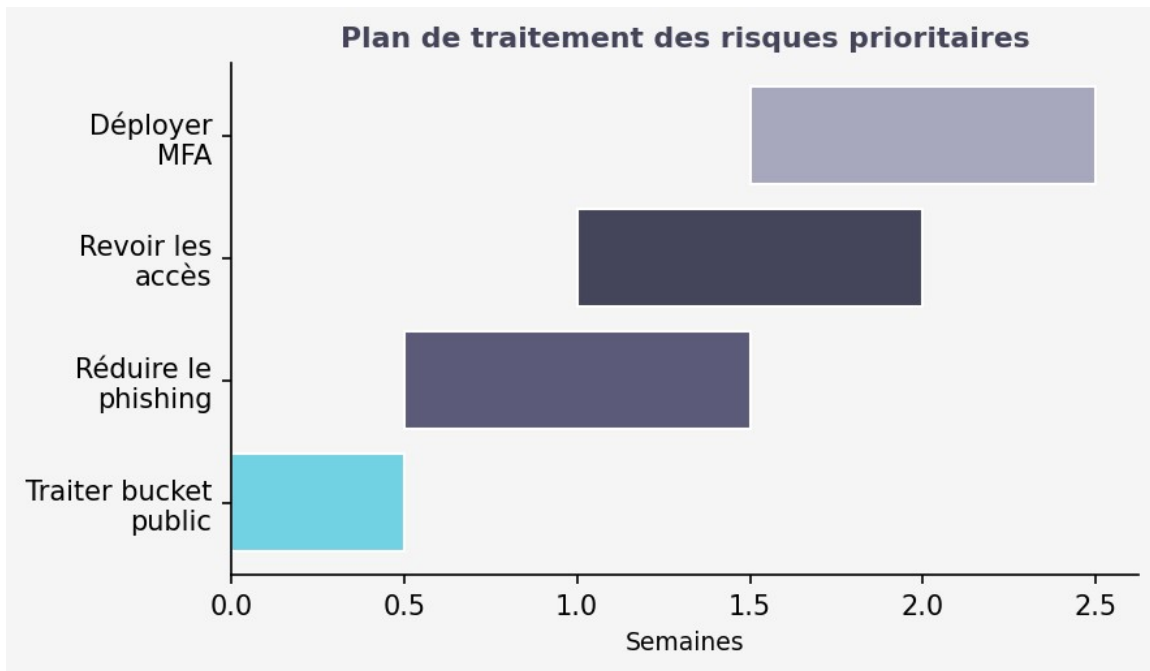
Note : l'étape 10 donne un exemple de positionnement pour les 5 risques déjà quantifiés à l'étape 6 ; complétez-le si votre recensement des menaces (partie a) en fait apparaître d'autres.

14. Proposez un plan de traitement daté des risques prioritaires.
15. Priorisez les mesures correctives selon la méthode MoSCoW.

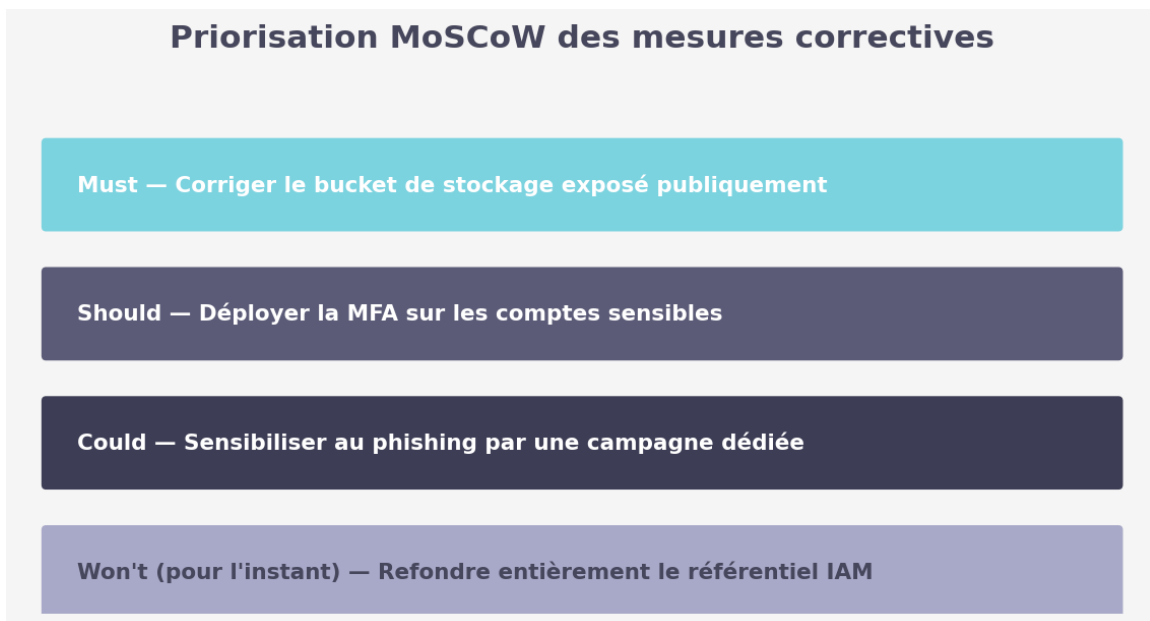
 Indication visuelle — Étape 10 : matrice 9-box de priorisation des risques



 Indication visuelle — Étape 11 : plan de traitement des risques prioritaires



 Indication visuelle — Étape 12 : priorisation MoSCoW des mesures correctives



Questions

- Quelles mesures correctives classez-vous en priorité Must ? Pourquoi ?
- Cette première analyse de risques vous semble-t-elle suffisante pour aborder la gestion des accès au chapitre 3 ?

Livrables attendus

18. Une cartographie documentée des menaces par domaine
19. Une matrice impact/probabilité des risques identifiés
20. Un plan de traitement priorisé (matrice 9-box + MoSCoW)
21. Nom du fichier rendu : TP_Guide_PentestCryptoUE2-2_Chapitre2_Nom_Prenom.pdf